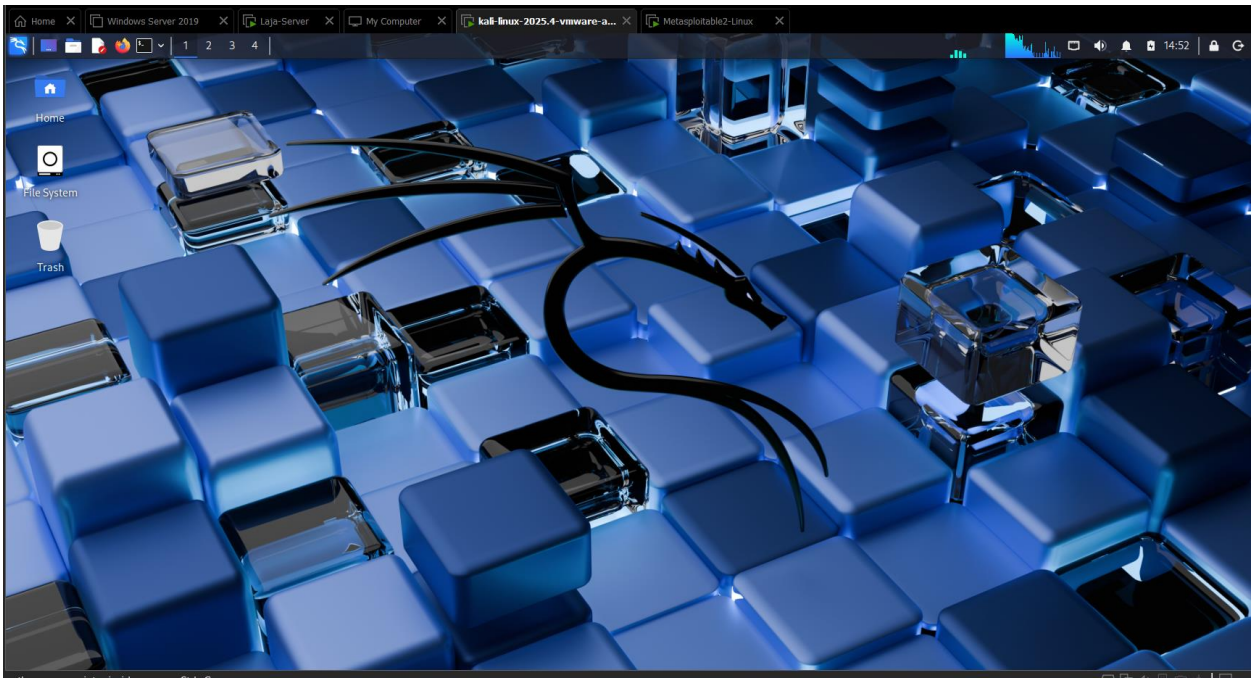
VULNERABILITY SCANNING ANALYSIS:

Introduction

In this project, a vulnerability scan was conducted on a Metasploitable virtual machine using the Nikto web server scanner. The purpose of the scan was to identify potential security weaknesses in the web server and understand how attackers may exploit them.

KALI LINUX VM:



METASPLOITABLE VM:

```
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started


metasploitable login: msfadmin
Password:
Last login: Sun May 20 15:50:42 EDT 2012 from 172.16.123.1 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

IP Address of Metasploitable:

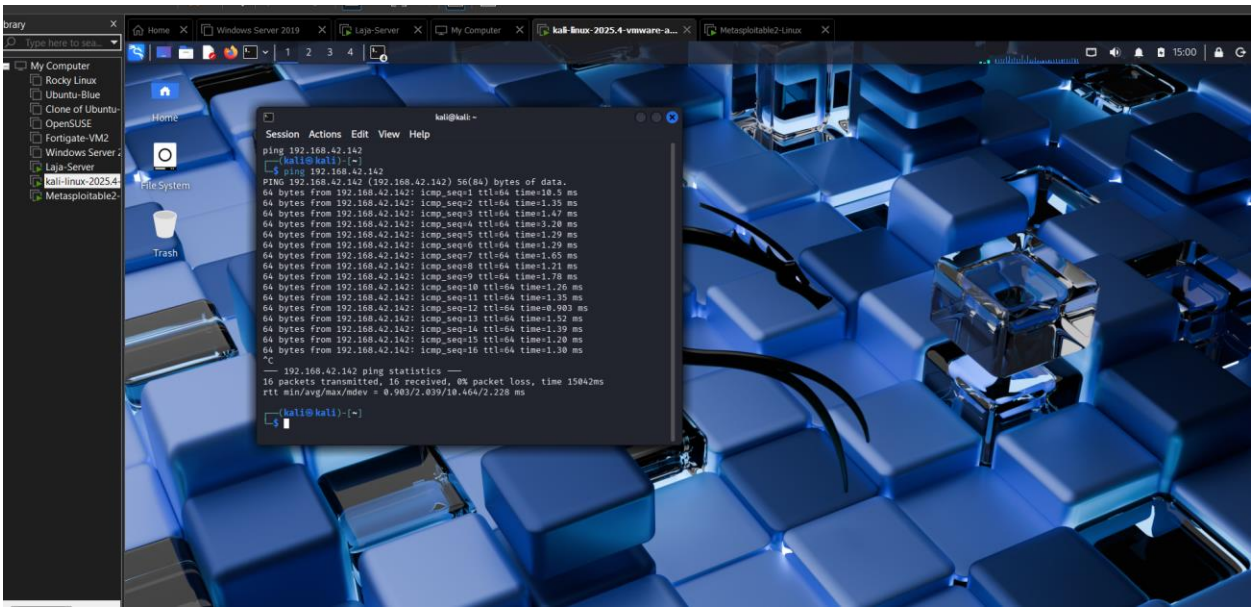
```
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ipconfig
-bash: ipconfig: command not found
msfadmin@metasploitable:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:c8:e5:32 brd ff:ff:ff:ff:ff:ff
    inet 192.168.42.142/24 brd 192.168.42.255 scope global eth0
    inet6 fe80::20c:29ff:fec8:e532/64 scope link
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:c8:e5:3c brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$ _
```

192.168.42.142

Ping Metasploitable from Kali Linux VM:



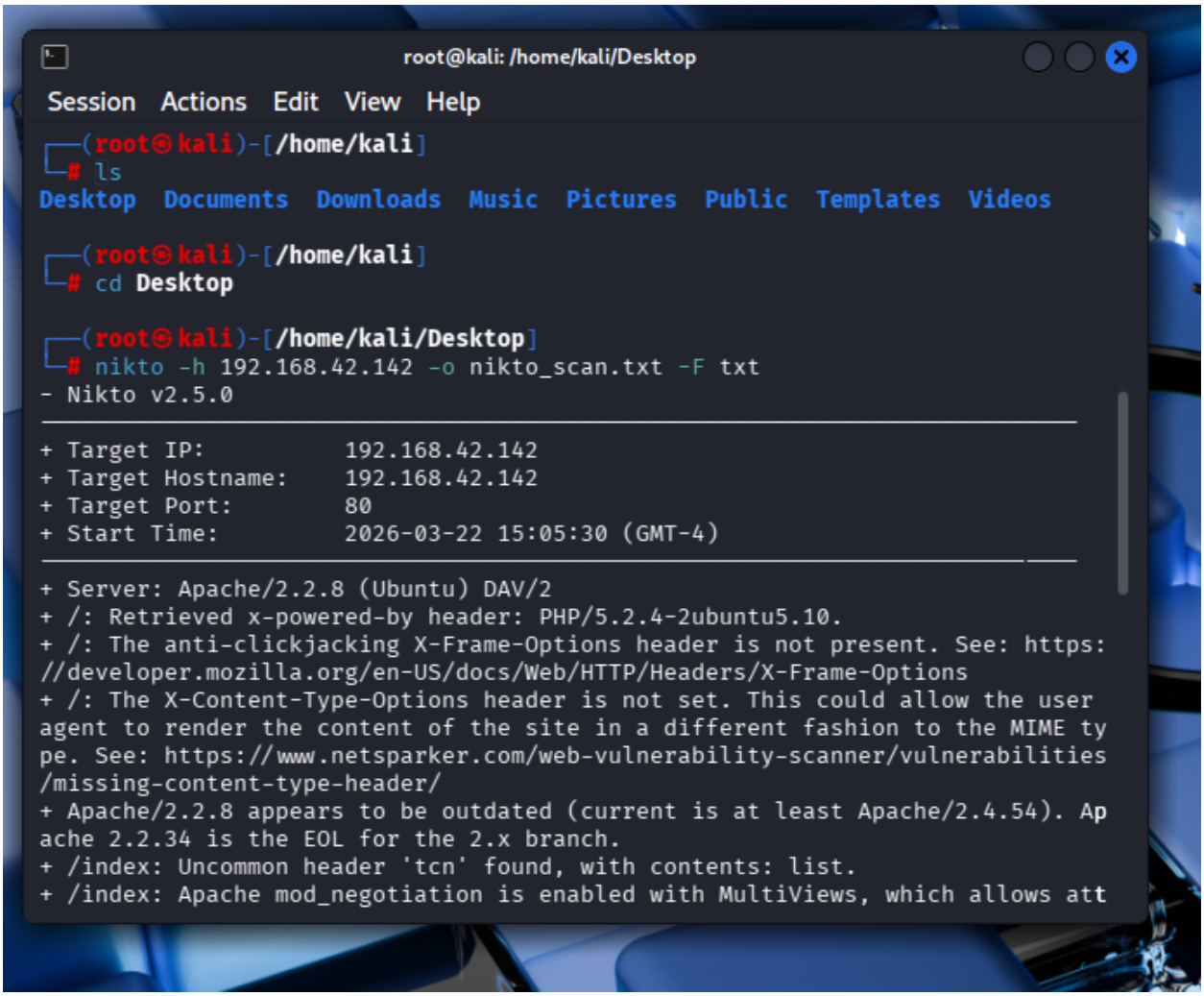
NIKTO SCAN:

Identified Vulnerabilities

1. Outdated Apache Web Server

The scan revealed that the server is running **Apache/2.2.8 (Ubuntu)**, which is outdated. Older versions of Apache contain known vulnerabilities that attackers can exploit to gain unauthorized access or disrupt services.

Risk: High — attackers can use publicly known exploits.



2. Missing Security Headers

Nikto reported that important security headers were not set:

- **X-Frame-Options missing**
- **X-Content-Type-Options missing**

These headers help protect against attacks like:

- Clickjacking
- MIME-type sniffing

Risk: Medium — makes the application more vulnerable to client-side attacks.

```
root@kali: /home/kali/Desktop
Session  Actions  Edit  View  Help
+ Target Port:        80
+ Start Time:         2026-03-22 15:05:30 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user
agent to render the content of the site in a different fashion to the MIME ty
pe. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities
/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Ap
ache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows att
ackers to easily brute force file names. The following alternatives for 'inde
x' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d1
5,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cau
se false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST
. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://
cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensiti
ve information via certain HTTP requests that contain specific QUERY strings.
```

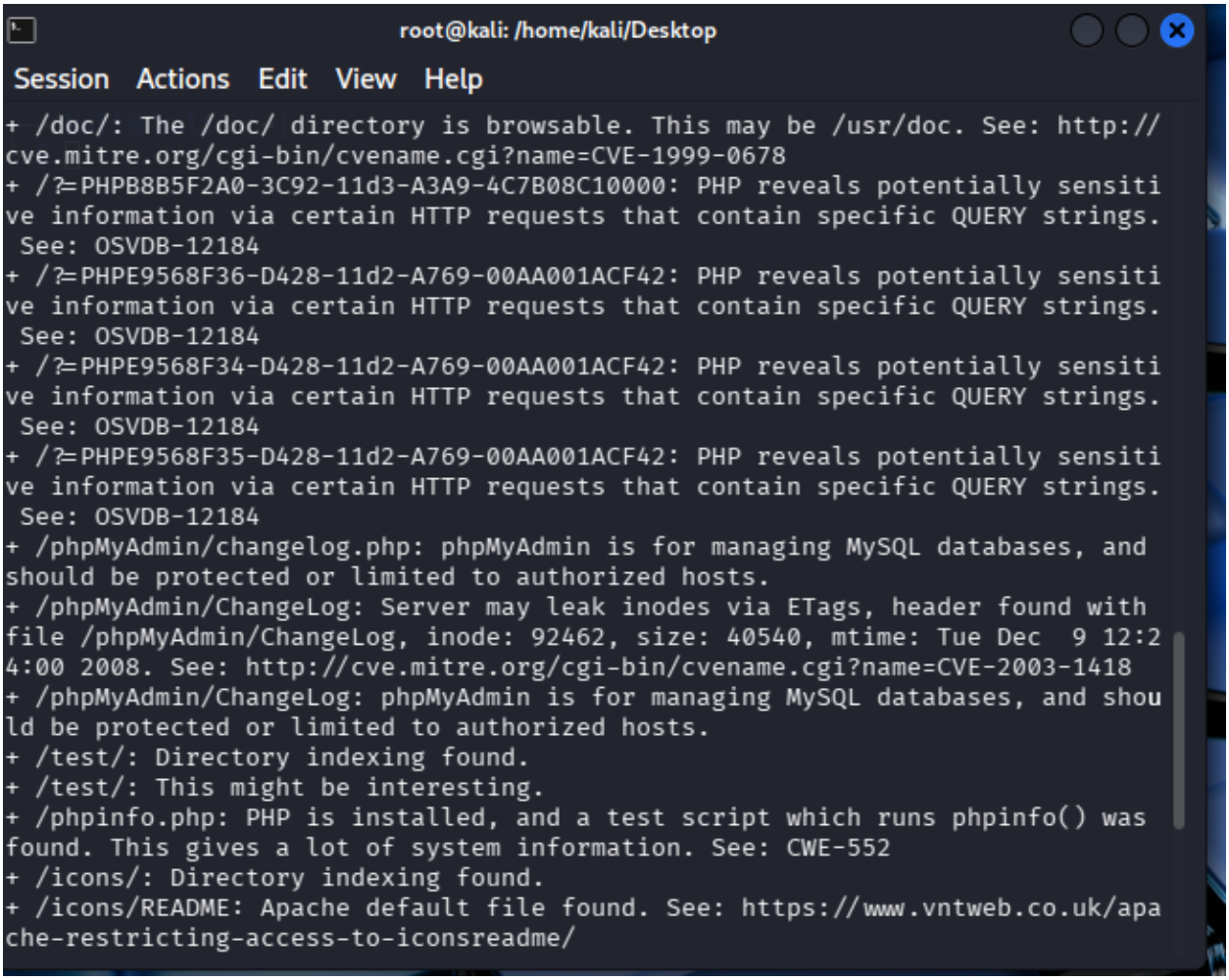
3. PHP Information Disclosure (phpinfo.php)

Nikto found a **phpinfo.php** file accessible on the server.

This file exposes:

- System configuration
- Installed modules
- Server environment details

Risk: High
Impact: Attackers can gather sensitive system information to plan targeted attacks.



4. Directory Indexing Enabled

The scan revealed directory indexing in multiple locations:

- /test/
- /icons/
- /doc/

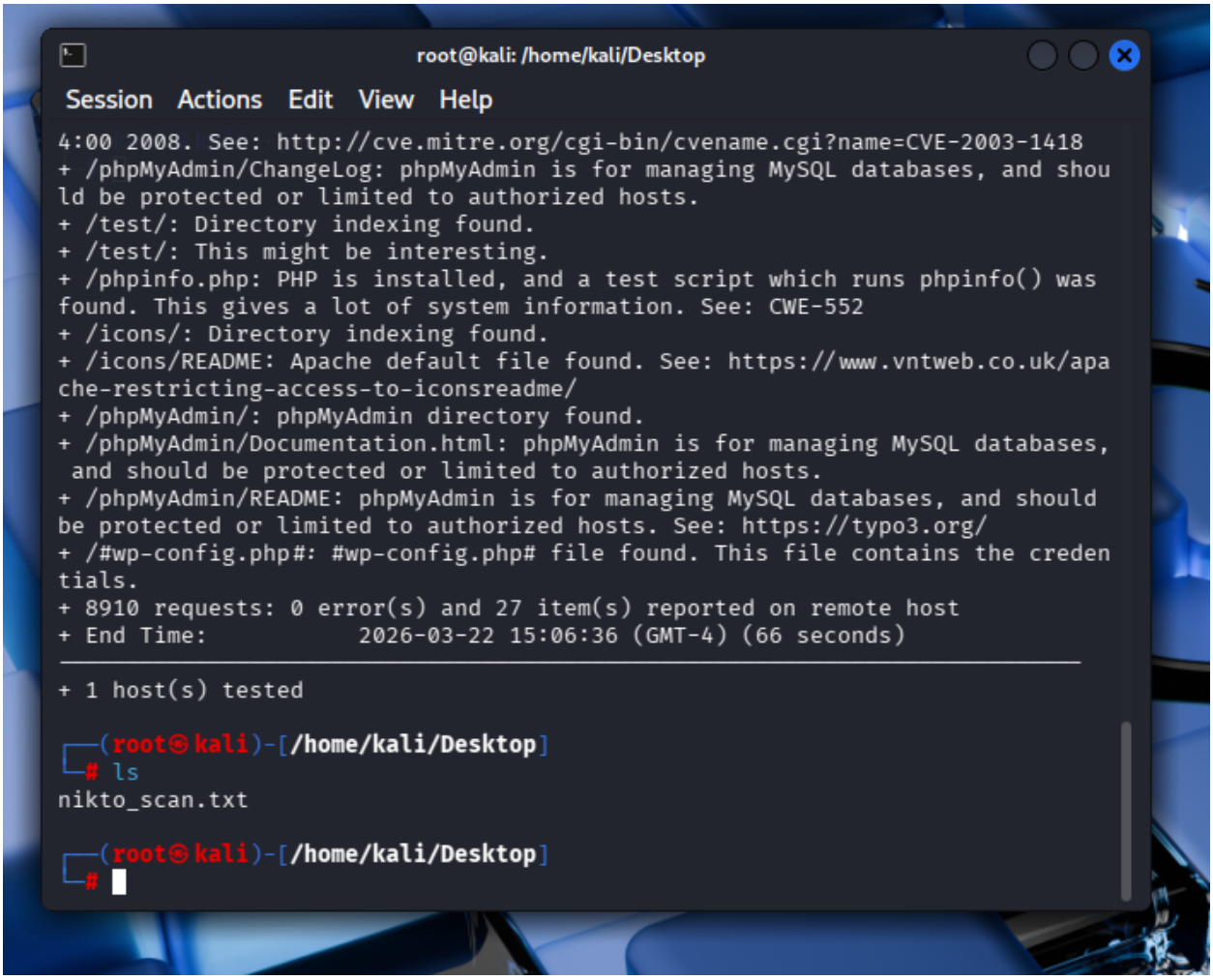
Risk: Medium
Impact: Attackers can browse directories and discover sensitive files or application structure.

5. Exposed Administrative Interface (phpMyAdmin)

Nikto detected the presence of:

- /phpMyAdmin/
- /phpMyAdmin/Documentation/
- /phpMyAdmin/ChangeLog

Risk: High
Impact: If not properly secured, attackers may attempt to access or exploit the database.



Conclusion

The Nikto scan identified several vulnerabilities in the Metasploitable web server, including outdated software, missing security headers, and information disclosure issues. These weaknesses demonstrate how poorly configured systems can expose organizations to cyberattacks. Regular vulnerability scanning and timely patching are essential to improve security and reduce risks.